

Playas y Ventajas — Relatório de Funcionalidades

Mapeado diretamente do código (rotas do App Router, endpoints do Worker, RPCs do banco).

Data: 01/10/2026 — inclui verificação do fluxo de indicação contra produção e estado do CI/CD.

1. Panorama e arquitetura

Camada	Tecnologia
Front (6 rotas, App Router)	Next.js 14 + React, i18n PT/EN/ES, tema próprio
Servidor	Cloudflare Pages — Worker em modo avançado, bundle self-contained (<code>_worker.js</code> , ~290 kB)
API	handlers em <code>netlify/functions</code> (CJS, fonte única — o espelho ESM <code>functions/.netlify/functions</code> foi removido em 2026-09-30), 26 rotas na whitelist (<code>worker/main.js</code> ROUTES; fora dela → 404)
Banco	Supabase (Postgres), regras de negócio em RPC, Storage de imagens/documentos, RLS ativa
Comunicação	WhatsApp (<code>wa.me</code>), QR code (qrcodejs, chip do logo 11,5% + nível H), mapa Leaflet + dados abertos OSM via Geoapify

2. Papéis do sistema

- Cliente** — identifica-se pelo telefone e resgata ofertas.
- Empresa** — estabelecimento que cria campanhas/cupons, aprova motoristas e valida cupons.
- Motorista** — parceiro que se cadastra, envia documentos e fica na frota.
- Admin** — operador da plataforma (gestão de negócios, clientes, planos, destaques).

3. Módulo Cliente (`/cliente`)

- Identificação por telefone** (`identify`): devolve `customerId` + token assinado (HMAC) anti-IDOR. Nome, Instagram e email são opcionais; **email não é mais verificado** (decisão registrada).
- Vitrine de ofertas** (`offers`): lista ativas por cidade, categoria e raio/distância (geolocalização), com imagens compensadas do catálogo.
- Mapa de proximidade**: radar (`find_nearby_businesses`) + camada de dados abertos OSM via `map-places` (Geoapify, servidor-side por CORS; chave nunca vai ao bundle, cache de 10 min e degradação para lista vazia em vez de erro — a instância pública do Overpass foi abandonada por 504/429 sob carga).
- Translado e proximidade**: card dedicado consumindo `shuttle` (`list_shuttle_services` + `list_live_vehicles`). Com geolocalização mostra distâncias e raio de 16 km; negada/indisponível ainda lista (sem `distanceKm`, aviso honesto). Veículos ao vivo mostram motorista, distância, velocidade e "atualizado há X"; sem dados → "Nenhum translado ativo por aqui no momento."
- Reservar translado / Minhas reservas** (Módulo A): agenda por serviço (`shuttle-reservation` → `shuttle_create_reservation`) com passageiros, data/hora, anotações e contato; painel "Minhas reservas" lista por status e permite cancelar (motivo opcional). Regras no banco: serviço ativo da empresa, dia ativo, janela de horário, sobreposição de slots (`tstzrange`) e fuso `America/Sao_Paulo` ; `SLOT_CONFLICT` é tratado na tela como "acabou de ser reservado". Confirmação da empresa acompanha o status em "Minhas reservas" + link `wa.me` .
- Resgate de cupom** (`claim-coupon`): caminho crítico roda RPC `claim_coupon` (estoque, hash, limite); extras best-effort: conversão de indicação (`try_referral_convert`) e link WhatsApp montado a partir do contexto do banco (nunca do navegador). Retorna QR code.
- Meus cupons** (`offers?mode=my-coupons`): exige token de cliente válido; status de resgate.
- Validação manual** (`validate-coupon`): código curto digitado, com códigos de recusa e idempotência.

4. Módulo Empresa (`/empresa`)

- Cadastro/login**: código interno + senha (PIN hashado, logout por tentativas); sem email/OTP desde a remoção de 2026-09-28.
- Painel** (`empresa`): relatório do negócio, dados próprios (`business_get_own` / `business_update_own`), telefone e logo.
- Campanhas e cupons**: cria campanha (`create_campaign`) e modelos de cupom (`create_coupon_template`), habilita/desabilita, atualiza e apaga — com benefício, estoque, imagem, modo "passeio" e proximidade.
- Gestão de motoristas**: convite (código `business-driver-invite`), lista de cadastros/detalhes, análise de documentos (`driver-review-document`), abertura do arquivo por **URL assinada de 5 min** (`driver-document-url` , storage privado), aprovação/recusa/suspensão.
- Validação de cupom** na tela e **troca de PIN** (`business_set_pin`).
- Upload de imagem** (`upload-image`): valida base64, MIME e tamanho; storage com path montado no servidor.
- Translado (self-service, escrita)**: aba "🚌 Translado" com CRUD dos próprios serviços (`business_save_shuttle_service` , `business_toggle_shuttle_service` , `business_delete_shuttle_service` , `business_list_shuttle_services`) — nome, descrição, tipo (shuttle/transfer/tour), origem/destino com "usar minha localização", preço em reais, horários, dias ativos e paradas (`Rótulo|lat|lng` por linha). Duração da corrida (15..720 min).

- **Aba "📄 Reservas"** (Módulo A): lista as reservas da empresa (`business_list_shuttle_reservations`) com filtro por status (pendentes/confirmadas/recusadas/canceladas/concluídas), data e motivo; decisão `confirm` / `reject` / `cancel` via `business_review_shuttle_reservation` (recusa exige motivo). Apenas o negócio do ator vê as próprias reservas (`SUPER_ADMIN` vê o tenant todo).
- **Relatório de performance** (`business_report_v3` , com degradação para a v2): períodos 7/30/90 dias; blocos `totals` (emitidos/validados/novos clientes), `daily` , `byCampaign` , `byTemplate` , `drivers` (mesmo escopo da aba Motoristas), `billing` (taxas cobradas), `shuttle` (serviços + veículos reportando) e `rides` (reservado).

5. Módulo Motorista (/motorista)

Fluxo completo com lógica pura testada em `app/motorista/logic.js` :

- **Cadastro** (`driver-register`): com código de convite da empresa; devolve `uploadToken` / `pinToken` .
- **Definir PIN** (`driver-set-pin`): `pinToken` é descartável (uma vez); `uploadToken` segue valendo para o documento.
- **Login** (`driver-login`): telefone + PIN, com lockout; emite sessão mesmo para `pending` / `rejected` (acesso ao app, não à frota); `suspended` → 403.
- **Documentos** (`driver-add-document`): upload de CNH/RG/CRV para storage privado, validação de MIME/conteúdo e limite de 6 MB; recusa exige novo envio.
- **Situação**: `pending` / `approved` / `rejected` / `suspended` ; só `approved` dirige (`canDrive`) e só `approved` aparece em `list_live_vehicles` (módulo 1).
- **Sessão e reidratação**: token de sessão OU token de cadastro (exatamente um por request); logout explícito.
- **Transmissão de posição** (`driver-position`): só `approved` envia; a posição é upsert em `vehicle_positions` (1 por motorista) com `shuttleId` opcional vinculado a um serviço ativo do próprio tenant; a UI "Transmissao de posicao" dá o botão Enviar (geolocalização), recarrega a lista de serviços e mostra a última posição registrada.
- **Minhas corridas de hoje** (`driver-shuttle-runs` → `driver_list_shuttle_runs`): só o motorista `approved` ; lista as reservas `confirmed` / `completed` do dia da frota dele (sem nome/telefone do cliente — agenda da rota) e o botão "Concluir corrida" (`driver_complete_shuttle_reservation` , `confirmed` → `completed`).

6. Módulo Admin (/admin)

- **Login** com checagem de papel `ADMIN` / `SUPER_ADMIN` (não basta entrar).
- **Negócios**: listar, criar (nome, CNPJ, logo, plano, dono com código+pin), ativar/desativar, editar, apagar.
- **Planos/faturamento**: painel `admin_billing_panel` , troca de plano. **Plano por cupom** (`PER_COUPON`): admin define `billing_fee_cents` no card do negócio; a cada resgate (`claim-coupon`) a taxa é acumulada em `billing_charges` (`coupon_id` preenchido, dedupe por cupom) e vista no painel `billing` — cobrança manual, sem assinatura MP (`billing_mp_prepare` recusa `PER_COUPON` com `PLAN_NOT_SUBSCRIPTION`).
- **Destaques**: `admin_featured_ranks` / `admin_set_featured` .
- **Clientes**: busca e edição (nome, email, Instagram, ativo).
- **Rreset de senha** de negócio (PIN temporário) e **reset de PIN de motorista** (`admin_driver_reset_pin`).

7. Módulo Afiliado (/afiliado)

- **Sem sessão**: o vínculo é por telefone, como no `/cliente` . `POST /api/affiliates` (`affiliate_register`) cria ou devolve o afiliado já existente — idempotente por `phone_digits` , então a mesma pessoa nunca recebe dois códigos de indicação.
- **Link e papel**: `shareUrl` = `/?ref=CODIGO` . A folha de divulgação sai pelo próprio navegador (Imprimir > Salvar em PDF), com marca, QR de 46mm, link, código, telefone e três passos — sem página, template ou fonte no servidor.
- **Painel**: `GET /api/affiliates?affiliateId&phone` → `affiliate_dashboard` devolve contadores, indicações e o **extrato de resgates**, tudo no mesmo contrato autenticado (nenhum endpoint novo).
- **Duas datas, porque não são o mesmo evento**:
 - `converted_at` — a indicação converteu, o que dispara no **claim** (a pessoa pegou o cupom). É quando o afiliado recebe a recompensa.
 - `coupons.validated_at` — o cupom foi validado no **caixa**, e pode nunca acontecer.

Chamar de "resgatado" o cupom que só foi pego faz o afiliado contar uma recompensa que ainda não existe, que é o número que ele usa para decidir se vale continuar divulgando. Por isso a tela rotula "pegou o cupom" e "resgatou no caixa" como estados distintos.

- **Extrato**: uma linha por indicação, com pessoa, cupom (título e código), estabelecimento, benefício, data e o código da recompensa recebida. O cupom exibido é o **primeiro emitido depois da indicação** — o que disparou a conversão. Filtrar por `status = 'VALIDATED'` daria a resposta errada: mostraria o cupom de outra visita e esconderia o cupom pego e nunca usado.
- **Recompensa**: `referral_track` registra a indicação (fail-open, exige `reward_status = 'active'` no afiliado) e `referral_convert` converte — cupom para o afiliado e cupom de boas-vindas para o indicado. A ponte é `try_referral_convert` , chamada por `claim-coupon.js` e `identify.js` .
- **Segurança**: o painel exige `affiliate_id` e telefone (comparado por `phone_digits` , então a máscara não quebra) e `tenant_id` ; qualquer um dos três errado devolve `null` — verificado em produção com telefone errado e com tenant errado. Nenhuma função de `public` aceita

EXECUTE de anon / PUBLIC (app_ainda_abertas = 0).

- **Estado dos dados:** o caminho com indicação real **foi exercitado contra o banco em 2026-10-01** e passou ponta a ponta. Um cliente novo entrou por ?ref=J0SDASCOUVE-EB29, resgatou PYV-198300510F (10% OFF, Edtec Seg Lagos) e o cupom foi depois validado no caixa. Resultado observado: referrals com status = 'converted', converted_at preenchida ~10 s depois do created_at, coupons.status = 'VALIDATED'. O extrato devolve a linha com os três estados coerentes.
 - **Prêmio ainda não creditado:** a conversão ocorreu sem reward_coupon_id. Há dois bloqueios empilhados, e só o primeiro era visível: (a) não há template de prêmio configurado em affiliate_rewards (require_first_claim também nulo) e (b) affiliates.customer_id **nunca era preenchido por ninguém** — affiliate_register não escreve essa coluna, e é dela que referral_convert tira o cliente para grant_coupon_internal. Mesmo com o template configurado, o prêmio sairia null para qualquer afiliado. Corrigido em supabase/affiliate-link-customer.sql, aplicado em produção em 2026-10-01.
 - **Diagnóstico agora é consultável:** affiliate_reward_status(tenant, affiliate) distingue ok, semCadastroCliente e semTemplate, e conta convertedCount / rewardedCount. Verificado em produção: convertedCount=1, rewardedCount=0, pendingReason="semCadastroCliente". Sem isso o afiliado via "1 indicação convertida" e nenhum cupom, sem motivo.
 - **Ordem corrigida em claim-coupon.js:** a ponte chamava try_referral_convert antes de referral_track. Como try_referral_convert delega para referral_convert, que seleciona a indicação pending do cliente — e quem insere essa linha é o próprio referral_track (modulo3-afiliados.sql:303) — a conversão procurava antes de a indicação existir, devolvia false, e o track registrava a indicação já como pending. Como identify.js só chama referral_track e nunca try_referral_convert, **ninguém mais convertia:** quem chegava pelo link e resgatava sem ter passado antes por /cliente ficava com uma indicação que nunca pagava prêmio. O caminho inverso (identify → claim) funcionava e escondia o bug. Havia um segundo problema na mesma região: o bloco vivia dentro de if (ctx), então se loadOfferContext falhasse a indicação não era registrada nunca — sem erro e sem aviso. Ambos corrigidos e travaram em tests/referral-order-guard.test.cjs (9 testes, verificados por mutação: invertendo as duas posições de volta, o teste de ordem falha).
 - try_referral_convert continua sendo chamada **sempre**, com código ou não — quem foi indicado num identify anterior chega ao resgate sem ?ref= e esta é a única oportunidade de converter a indicação dele.
 - O que continua travado em tests/afiliado-extrato-guard.test.cjs são as regressões estruturais: agregação aninhada (o 42803 que já derrubou admin_affiliate_report), escolha do cupom errado, e a confusão entre "pegou" e "resgatou".

8. Regras de negócio no banco (RPCs)

Grupos por domínio (96 funções de app em public, EXECUTE fechado para o cliente — app_ainda_abertas = 0):

- **Autenticação:** auth_login, register_business, reset de senha/PIN. auth_login_by_email e register_business_by_email **removidas** (migração drop_email_auth).
- **Ofertas/busca:** list_offers, list_offers_public, list_cities, list_customer_coupons, business_logo_by_id, find_nearby_businesses, set_coupon_proximity, featured.
- **Cupons:** claim_coupon, validate_and_redeem_coupon, grant_coupon_internal.
- **Motoristas:** driver_register/set_pin/login/logout/verify_session/add_document/review_document/list_documents/list_for_business/get_document_path, admin_driver_reset_pin.
- **Empresa:** business_get_own, business_update_own, business_report, business_report_v3 (Módulo C), business_generate_invite, business_logo_by_id.
- **Admin:** gestão de negócios/faturamento/clientes/destaques/delete.
- **Faturamento fase 2:** billing_record_coupon_tax (taxa por resgate em PER_COUPON, dedupe por coupon_id), billing_mp_prepare/register/cancel e webhooks MP recusam/ignoram PER_COUPON.
- **Afiliados/indicação:** RPCs (affiliate_register, affiliate_report, referral_track, referral_convert, try_referral_convert, get_referral_bonus) consumidas pelas telas /afiliado (cadastro, link com QR, painel com extrato de resgates) e pela seção Afiliados do /admin. affiliate_dashboard é STABLE e valida affiliate_id + phone_digits + tenant_id na própria função — sem anon executing, sem sessão.
- **Translado/proximidade (Módulo 1, leitura):** RPCs list_shuttle_services e list_live_vehicles com UI dedicada em /cliente (card "Translado e proximidade").
- **Translado/proximidade (Módulo 1, escrita):** business_save_shuttle_service, business_toggle_shuttle_service, business_delete_shuttle_service, business_list_shuttle_services e driver_report_position (supabase/translado-write-flow.sql, aplicado) — SECURITY DEFINER com autorização dentro da função (ator da empresa via users.business_id; motorista via sessão driver_sessions, status='approved', driver_id nunca vem do cliente), EXECUTE só service_role.
- **Agendamento (Módulo A, supabase/agendamento.sql, aplicado):** shuttle_create_reservation, shuttle_cancel_reservation, shuttle_list_customer_reservations, business_list_shuttle_reservations, business_review_shuttle_reservation, driver_list_shuttle_runs, driver_complete_shuttle_reservation + tabela shuttle_reservations (RLS ativa sem policy; acesso só via RPC admin com service_role) e shuttle_services.duration_minutes (15..720).
- **Notificações (Módulo B, supabase/notificacoes.sql, aplicado):** outbound_enqueue (única escrita; dedupe por evento/canal/cupom/reserva), outbound_mark_sent, outbound_mark_failed (idempotentes), outbound_list (auditoria) + tabela outbound_messages (fila/auditoria; default no-op provider='none' até haver provedor real).

9. Segurança (estado atual)

- Erro interno **nunca** em resposta HTTP (sanitizado em 500/409, ambos dialetos) — 2026-09-28.
- Erros de sessão são contrato `401` (`SESSION_REQUIRED` / `SESSION_EXPIRED`).
- Tokens de cliente HMAC (anti-IDOR); storage privado com URL assinada; `no-store` em rotas de sessão; CORS controlado.
- PIN hashado + logout em memória e `login_attempts`; `search_path` fixo; `REVOKE` de `function_exec`; RLS ativa.
- Pendências registradas em **SECURITY-DECISIONS.md** (inclui vazamento de credenciais numa conversa anterior — rotação a critério do dono).
- Bateria de segurança da fase 2 (2026-09-29): apenas `service_role` executa as funções de app (regra 4 → `app_ainda_abertas=0`); `billing_record_coupon_tax` não aparece nos advisors de `SECURITY DEFINER` exposto (anon/authenticated). Único ERROR restante é `spatial_ref_sys` sem RLS — catálogo de SRIDs da extensão postgis, owned por `supabase_admin`; o `ALTER TABLE ... ENABLE ROW LEVEL SECURITY` exige ownership/superuser e falha com `42501 must be owner` tanto no MCP quanto no SQL Editor do dashboard (ambos rodando como `postgres`, não-superuser, sem membership em `supabase_admin`; grants feitos pelo `supabase_admin` — sem caminho SQL). **Risco aceito e documentado em SECURITY-DECISIONS.md** (dado de referência, sem PII; remediação exigiria intervenção do Supabase).

10. Qualidade

- **439 testes / 433 passando / 0 falhas / 6 pulados** (`node:test`) — cobrem handlers, lógica pura, contrato do diretório de functions, headers e asset routing do Worker. Módulos: `empresa-reservations.test.cjs` (9 casos do `GET mode=reservations + review_reservation`), `notificacoes.test.cjs` (fase 1 no-op + erros), `empresa-report.test.cjs` (report v3 com fallback v2), `shuttle.test.cjs` (10 casos de contrato/erro do endpoint de traslado), `shuttle-manage.test.cjs` (15 casos do fluxo de escrita do Módulo 1), `afiliado-folha-guard.test.cjs` (folha de papel no `window.print()`), `afiliado-extrato-guard.test.cjs` (extrato: agregação não aninhada, cupom da indicação, "pegou" ≠ "resgatou"), `afiliado-premio-guard.test.cjs` (15 guards do vínculo cliente→afiliado, incluindo o que trava a troca de `affiliate_id` por `referred_user_id`) e `referral-order-guard.test.cjs` (9 casos da ordem das RPCs de indicação, com prova por mutação).
- Os guards de afiliado travam **código-fonte** porque este runner não renderiza JSX nem executa SQL. Consequência aceita: o caminho do extrato continua sem cobertura automatizada de banco (a verificação de 2026-10-01 foi manual, contra produção — ver seção 7). O mesmo vale para `affiliate-link-customer.sql`, que foi aplicado e conferido por consulta manual em produção.
- O teste de segurança do `/api/health` usa valores deliberadamente distintivos (`service-role-NAO-VAZAR-123`) e falha se qualquer um aparecer na resposta, então um vazamento de segredo é detectado pelo nome e não por acaso.
- Testes **live opcionais** (smoke, aprovação de motorista e reporte de posição) rodam com `RUN_LIVE=1` contra produção (`npm run test:live[:approval[:position]]`).
- Build gera Worker autocontido; rotas fora da whitelist → 404.

11. Operação e entrega (2026-10-01)

- **CI/CD**: `.github/workflows/deploy.yml` publica a `main` no Cloudflare Pages a cada push — `npm ci`, testes, `npm run build`, verificação de `out/worker.js` e `wrangler-action`. Usa `CLOUDFLARE_API_TOKEN` (escopo Pages) e `CLOUDFLARE_ACCOUNT_ID` como secrets do repositório; o OAuth local do Wrangler expira em horas e **não** serve para o CI.
- **Variáveis de ambiente**: as cinco (`NEXT_PUBLIC_SUPABASE_URL`, `NEXT_PUBLIC_SUPABASE_ANON_KEY`, `SUPABASE_SERVICE_ROLE_KEY`, `RESEND_API_KEY`, `GEOAPIFY_API_KEY`) existem em **Production e Preview**, todas como `secret`. Havia `SUPABASE_SERVICE_ROLE_KEY`, `RESEND_API_KEY` e `GEOAPIFY_API_KEY` em texto claro no Preview; as três foram trocadas por valores novos e as antigas revogadas. `scripts/.agent-scripts/check-pages-env.ps1` audita nome/tipo/presença sem imprimir valor, e é o que impede a regressão.
- **Domínio**: produção responde em `https://playas-y-ventajas.pages.dev`. `playas-y-ventajas.com` **não está registrado** (NXDOMAIN) — links de indicação e material impresso devem usar o endereço do Pages até haver domínio próprio. `NEXT_PUBLIC_SITE_URL` não existe no Pages; `_wa.js` usa `pages.dev` como reserva.
- **Monitoramento**: existe `GET /netlify/functions/health` (público, sem autenticação por decisão — um health check que exige login não serve nem para uptime monitor externo nem para quem está com o navegador travado). Devolve `503` quando alguma dependência **não opcional** falha ou falta, e `200` quando tudo está de pé, para o painel de uptime conseguir notificar. Verificado em produção em 2026-10-01: `503`, quebradas: [`"mercadopago"`], `supabase: ok` (testar `rpc`) — a chamada real ao banco passou. O corpo carrega só nome de integração e `ok` / ausente / erro, nunca valor de variável.
 - **Mercado Pago está inoperante** — achado pelo próprio endpoint, não por inspeção. As três variáveis não existem no Pages: `MP_ACCESS_TOKEN`, `MP_NOTIFICATION_URL` e `MP_WEBHOOK_SECRET`. Consequência: `billing.js:80` lança sem o token, então **a assinatura mensal falha**; sem `MP_NOTIFICATION_URL` o cliente não tem para onde voltar; e `billing-webhook.js:79` devolve `500` em todo webhook que chegar. Nenhum outro módulo depende disso, então o site como um todo não cai. Depende de decisão do dono: ativou a cobrança recorrente ou não.
 - Ainda falta: alerta configurado no painel do Cloudflare (o endpoint dá o sinal, ninguém foi avisado dele), contagem de uso da Geoapify (3000 req/dia no plano grátis) e verificação do QR de 11,5% com a câmera do aparelho.